

A exceção é o teste diário da autoridade do programa: o sistema que não suporta autenticação multifator, o fornecedor que não aceita a cláusula, a aplicação que precisa subir antes da correção. O fluxo abaixo é o formulário; a tabela de alçadas diz quem concede o quê, por quanto tempo e com qual compensação.

O fluxo · da solicitação ao fechamento, sempre pelo registro central

1

Solicitação formulário único, pela área que precisa da exceção

Padrão que se pretende descumprir: · Motivo: · Duração pedida: · Compensação proposta: · Solicitante e data:

2

Análise da segurança avalia e recomenda; não concede

Parecer, nível de risco pelas escalas declaradas, compensatório exigido:

3

Aprovação pela alçada do nível conforme a tabela abaixo

Aprovador, cargo, data e assinatura:

4

Registro central, com data de vencimento exceção fora do registro é política alterada pela porta dos fundos

Identificador da exceção: · Vencimento: · Responsável pelo acompanhamento:

5

Fechamento solução definitiva ou renovação fundamentada, nunca por decurso de prazo

Como se encerrou, quando, e quem confirmou:

Alçadas · quem aprova, por quanto tempo, com qual compensação

Nível	Quem aprova	Prazo máx.	Compensação	No vencimento
Baixo · sistema não crítico e sem dado pessoal	Gestor da área, com registro	12 meses	Monitoramento	Renovação com nova justificativa
Médio · sistema relevante ou dado pessoal comum	Diretor da área, com parecer da segurança	6 meses	Compensatório declarado e verificado	Volta ao fórum
Alto · dado sensível, sistema crítico ou obrigação regulatória	Fórum de risco com o negócio	90 dias	Compensatório em operação, com evidência	Bloqueio automático, salvo renovação prévia

O erro mais comum: exceção concedida por e-mail. Não entra em registro central, ninguém lista quantas existem, e não tem vencimento: a política foi alterada pela porta dos fundos, sem passar por quem a aprovou. A lista de exceções vencidas e ativas é o achado mais eloquente que uma auditoria encontra sobre maturidade.